

U3 L20 Network Scanning Detection Lab

U3 L20: GITHUB LAB — Network Scanning Detection Lab (Dec 11, Fri — TECH DAY)

⚡ **HW Quiz (5 min):** 3 MCQ on detection concepts (NIDS/NIPS, SIEM).

Learning Objectives:

- 3.5.A Explain how NIDS/NIPS detect network attacks
- 3.5.B Explain SIEM functions and log correlation
- 3.1.B Apply ARP-flood detection heuristics to a captured network trace

Materials: Repo: `ivycollegiate-development/network-scanning-detection-lab` (composite pcap + scan artifacts), Wireshark (local or Wireshark Online), Snort/Suricata rule reference sheet, response-playbook worksheet

Lesson note (added Sep 26, 2026): This lab now ships a purpose-built **composite capture**, `composite_arp_lesson.pcap`, which replaces the generic pre-captured scans. It contains three deliberate segments on a single timeline — a benign baseline, a real ARP flood, and a **benign authorized asset scan that looks like an attack**. Exactly one of the two high-volume segments is an attack, and students are not told which. See the appendix for the exact windows and the answer key.

Activities

1. **Concept primer (10 min):** NIDS (monitor and alert) vs NIPS (monitor and block inline). Signature-based vs anomaly-based detection. SIEM — collect, normalize, correlate, alert, dashboard. Correlation: time-based, pattern-based, threshold-based. Examples: Snort/Suricata, Splunk, ELK, Wazuh. (Condensed from the original 2-day 3.5 sequence to fit the compressed calendar.)
2. **Demo — the three-segment capture (6 min):** Open `composite_arp_lesson.pcap` in Wireshark. Display filter `arp`. Walk the class through the timeline: normal traffic, then a flood, then a scan. **Do not reveal which of the last two is malicious.**

3. **Lab — identify and justify (22 min):** In pairs, students load the capture and, for each high-volume segment, determine: (a) is this an attack or authorized activity, (b) what specific evidence supports that call, (c) a Snort-style or SIEM correlation rule that would flag the malicious one *without* flagging the benign one, (d) one response action per finding. They must submit their own answer for both segments — a student who labels the scan as malicious has not passed the lab, because the rule they write will produce a false positive on authorized inventory work.

4. **Wrap-up (7 min):** Submit via GitHub Classroom. Class discussion: why is request *volume* a poor detection signal on its own? **Winter Break assignment assigned:** Unit 4 device inventory (list every device you own + its attack surface) + pre-read of 4.1–4.2 CED excerpt. Collected Jan 4.

Homework (due Sun 20:30 — Monday Dec 14 quiz): Finish lab. Start the Winter Break device inventory.

Differentiation / ELL support: The discriminators are structural (one source vs many, sequential vs scattered, replies vs none) rather than tool-specific, so the lab can be completed from printed packet listings. Provide the pcap as a table of timestamp / source / target / op / reply-yes-no for students who cannot run Wireshark.

Assessment notes: Grading focus is correct identification of the storm **and** correct exoneration of the scan, with evidence. A student who flags both has demonstrated the exact failure mode this lab targets and should lose credit for the false positive. Lab infrastructure is unchanged — the pcap ships in-repo, no new accounts, no setup time. The `paper-fallback.md` in the repo carries the equivalent worksheet.

Appendix — Composite Capture Design

File: composite_arp_lesson.pcap · 980 packets · 96.9 s · 56 KB **Topology:** all addresses synthetic — 192.168.10.0/24, MACs 02:00:00:.... No real hosts, no real traffic.

Act	Relative time	Content
1 — Baseline	0 – 26 s	Gateway ARP request/reply pairs, 8 DNS lookups, 3 TCP/443 handshakes
2 — ARP storm	28 – 74 s	622 ARP who-has, zero replies
3 — Decoy (benign)	82 – 97 s	Authorized asset scan sweeping .2 – .253, single source , gets replies

The three discriminators — in priority order:

1. **Reply behaviour (strongest).** The flood gets **0 replies**. The scan gets replies, because real hosts answer a legitimate sweep. *Unanswered ARP is the tell.*
2. **Source count.** Storm = 2 senders (192.168.10.77 plus 192.168.10.50 spoofed). Scan = 1 sender (192.168.10.200).
3. **Target pattern.** Scan = sequential sweep, 223/279 adjacent steps (~80%). Storm = scattered targets, 7/536 (~1%).

Deliberate design choices — do not “simplify” these:

- **Request rate does NOT separate them.** The decoy runs 69–110 who-has per 5 s; the storm’s quieter stretches run 41–89. The bands overlap on purpose, so a student thresholding on volume alone gets a wrong answer and is forced into structural analysis. An earlier build had the decoy at 10–15/5 s, which made rate a valid shortcut and defeated the lesson.
- **No address collisions between acts.** The decoy’s responding hosts are .5, .11, .23, .101, .140 — deliberately **not** .77, the attacker. Reusing it would let a student dismiss the storm as “just a scan.”
- **Source-IP spoofing inside the storm.** ~25% of storm packets are attributed to 192.168.10.50 (the victim), modelling an attacker attempting cache poisoning. The two-source signature is intentional and is itself a detection cue.

Expected student error to plan for: most will flag *both* high-volume segments. That is the designed outcome — it motivates the false-positive discussion, and the “looks bad ≠ is bad” framing is the transferable lesson.

Snort-style rule sketch (for discussion, not for the answer key):

```
alert arp any any -> any any (msg:"ARP flood: >100 req/5s, no
replies";
  threshold: type both, track by_src, count 100, seconds 5;
  sid:1000001; rev:1;)
```

Students still need the source-count and sequential-sweep checks; a pure threshold fires on the authorized scan.

Provenance caveat: the storm’s packet cadence is derived from the CCM/CDP 2012 ARP-flood dataset, re-timestamped and anonymized. Describe it to students and to the College Board as *realistic*, not as a forensically authentic capture.